

Die EU Datenschutz-Grundverordnung (DSGVO)

Die Datenschutz-Grundverordnung (DSGVO) stellt eine Reihe von Anforderungen an IT-Projekte, um den Schutz personenbezogener Daten zu gewährleisten. Es geht um den Schutz sensibler Kunden- oder Mitarbeiterdaten. Versicherer verarbeiten Informationen, die oft intime Einblicke in das Privatleben der Versicherten gewähren, wie Gesundheitsdaten, finanzielle Details und persönliche Identifikationsmerkmale. Hierbei kommt neben der Einhaltung gesetzlicher Vorgaben wie der Datenschutz-Grundverordnung (DSGVO) auch dem Prinzip der Datensouveränität große Bedeutung zu. Es gilt, die Daten nicht nur sicher zu speichern, sondern auch sicherzustellen, dass sie ausschließlich zu den klar definierten Zwecken verwendet werden. Technische Maßnahmen wie Verschlüsselung und regelmäßige Sicherheitsupdates müssen mit organisatorischen Maßnahmen – etwa durch transparente Datenschutzrichtlinien und regelmäßige Schulungen der Mitarbeiter – kombiniert werden. Kunden müssen jederzeit nachvollziehen können, welche Daten erhoben werden, wie diese verarbeitet und wie lange sie gespeichert bleiben. Mechanismen zur Einholung und zum Widerruf von Einwilligungen sowie zur Durchführung von Löschaufträgen sollten intuitiv und einfach zugänglich gestaltet sein. Unternehmen müssen nachweisen können, dass sie die DSGVO-Anforderungen erfüllen. Dies umfasst die Dokumentation aller Datenschutzmaßnahmen und -prozesse.

Es handelt sich hier um einen hochsensiblen Themenbereich, der erfordert, dass der Datenschutzbeauftragte frühzeitig in alle IT-Vorhaben einbezogen wird. Ein Datenschutzvergehen wird fast immer öffentlich und kann die Reputation eines Unternehmens massiv beschädigen. Auf das „sicher“ in „Versicherung“ muss sich der Kunde auch in Bezug auf seine Daten verlassen können.

Das Betriebsverfassungsgesetz

Im Betriebsverfassungsgesetz (§ 87 Abs. 1 Nr. 6 BetrVG) ist ein Mitbestimmungsrecht des Betriebsrats bei der Einführung neuer IT-Systeme geregelt. Dies gilt insbesondere dann, wenn IT-Systeme eingeführt werden, die potenziell zur Überwachung von Leistung und Verhalten der Mitarbeiter genutzt werden können. Beispiele für solche Systeme sind: Zeiterfassungssysteme, Office-Software, CRM-Systeme oder Kernversicherungssysteme. Der Betriebsrat kann sowohl über das „Ob“ der Einführung als auch über das „Wie“ der Anwendung dieser Systeme mitentscheiden. Der Arbeitgeber muss den Betriebsrat daher rechtzeitig und umfassend über die geplante Einführung des neuen IT-Systems informieren. Dies umfasst Details zur Funktionsweise, den Zweck und die Auswirkungen auf die Arbeitnehmer. Bereits im Stadium „Idee“ sollte daher ein neues Projekt dem Betriebsrat zur Kenntnis gebracht werden. Erst wenn diese Kenntnisnahme bestätigt ist, darf das Projekt in den Stage-Gate®-Prozess gehen. In allen Projektphasen sollte ein enger Kontakt zum Betriebsrat gepflegt werden zur Ge-

staltung und Anwendung des Systems. Das vermeidet späteren Ärger bei der Einführung des fertigen Systems.

Die Ausgliederung von Versicherungstätigkeiten

Eine Ausgliederung im Sinne des Versicherungsaufsichtsgesetzes ist die Übertragung von Funktionen oder Versicherungstätigkeiten eines Versicherungsunternehmens auf externe Dienstleister. Eine wichtige Ausgliederung bezieht sich auf Funktionen und Prozesse zur ordnungsgemäßen Geschäftsführung und zur Einhaltung aufsichtsrechtlicher Vorschriften.

■ BEISPIELE FÜR WICHTIGE IT-AUSGLIEDERUNGEN:

Cloud-Dienste wie Microsoft365, ein CRM- oder ein Kernversicherungssystem, IT-Sicherheitsdienste wie Firewalls oder Intrusion Detection Systeme, Vergabe von Entwicklung und Wartung von Versicherungssoftware an spezialisierte IT-Dienstleister, Datenverarbeitungs- und Datenanalyseaufgaben oder zentrale IT-Infrastruktur. ■

Solche Ausgliederungen sind entscheidend für die Effizienz und Sicherheit der IT-Systeme in Versicherungsunternehmen und sind daher den strengen Anforderungen des Versicherungsaufsichtsgesetzes unterworfen.

Bei IT-Projekten in der Versicherungsbranche gibt es mehrere wichtige Aspekte:

- **Anzeigepflicht:** Versicherungsunternehmen müssen die Absicht, wichtige Funktionen oder Versicherungstätigkeiten auszugliedern, unverzüglich der BaFin anzeigen. Dies umfasst die Vorlage des Vertragsentwurfs und detaillierte Informationen zur Ausgliederung. Darüber hinaus müssen Vollzug, wesentliche Änderungen und schwerwiegende Vorfälle im Ausgliederungskontext gemeldet werden. Hier gibt es eine Überschneidung mit der neuen Meldepflicht von IKT-Dienstleistung gemäß DORA über das sogenannte IKT-Informationsregister, wobei vorerst noch das VAG vorgeltend ist.
- **Schriftliche Leitlinien:** Für ausgegliederte Funktionen und Versicherungstätigkeiten müssen schriftliche Leitlinien beschlossen werden, um die Einhaltung aller aufsichtsrechtlichen Vorschriften sicherzustellen.
- **Ausgliederungsbeauftragter:** Es muss ein Ausgliederungsbeauftragter benannt werden, der die Ausgliederung überwacht.
- **Letztverantwortung:** Die Geschäftsleitung bleibt letztverantwortlich für die ausgegliederte Funktion oder Versicherungstätigkeit und kann diese Verantwortung nicht delegieren.
- **Risikoanalyse und Auswahl des Dienstleisters:** Eine gründliche Risikoanalyse und sorgfältige Auswahl des Dienstleisters sind erforderlich, um sicherzustellen, dass die ausgegliederten Aufgaben ordnungsgemäß ausgeführt werden.

- **Inhalt von Outsourcing-Verträgen:** Die Verträge müssen klare Regelungen zur Erfüllung der aufsichtsrechtlichen Anforderungen enthalten.

Diese Punkte helfen sicherzustellen, dass die IT-Projekte im Haus den gesetzlichen Anforderungen entsprechen und die Risiken minimiert werden.

Das Barrierefreiheitsstärkungsgesetz (BFSG)

Das Barrierefreiheitsstärkungsgesetz (BFSG) gilt seit Juni 2025 und legt den Schwerpunkt darauf, dass digitale Anwendungen und Applikationen so gestaltet werden, dass sie für alle Nutzergruppen unabhängig von möglichen Einschränkungen uneingeschränkt zugänglich und nutzbar sind. Bei der Einführung neuer Applikationen müssen einige Aspekte beachtet werden:

Die Applikationen müssen den international anerkannten Richtlinien zur Barrierefreiheit entsprechen. Dort werden Anforderungen definiert, wie Inhalte zu gestalten sind, dass sie zum Beispiel für Menschen mit Seh-, Hör- oder motorischen Einschränkungen zugänglich sind.

Ein weiterer wichtiger Punkt betrifft die technische Umsetzung:

- **Kompatibilität mit assistiven Technologien** wie Screenreadern, Spracherkennungssoftware und anderen Hilfstechnologien.
- **Navigation und Bedienbarkeit:** Es muss sichergestellt sein, dass sämtliche Funktionen auch rein über die Tastatur (ohne Maus) erreichbar sind.
- **Textalternativen und visuelle Gestaltung:** Bilder und multimediale Inhalte müssen mit aussagekräftigen Alternativtexten versehen sein, die den Inhalt beschreiben. Auch der Kontrast zwischen Text und Hintergrund sollte ausreichend hoch sein, um die Lesbarkeit zu gewährleisten.
- **Interaktive Elemente und Feedback:** Formulare und andere interaktive Elemente müssen so gestaltet werden, dass sie auch von Menschen mit eingeschränkten motorischen Fähigkeiten problemlos bedient werden können. Hierzu gehört auch, dass Fehlermeldungen und Hinweise eindeutig und verständlich kommuniziert werden.

Darüber hinaus ist es wichtig, dass der Entwicklungsprozess von Beginn an unter dem Gesichtspunkt der Barrierefreiheit konzipiert wird. Das bedeutet, dass bereits in der Planungsphase potenzielle Barrieren identifiziert und durch entsprechende Maßnahmen adressiert werden. Eine regelmäßige Überprüfung durch interne Tests sowie externe Zertifizierungen oder Usability-Tests mit Nutzergruppen, die unterschiedliche Bedürfnisse repräsentieren, stellen sicher, dass die Applikationen den Anforderungen des BFSG auch langfristig gerecht werden. Hierzu sollte auch ein Prozess für Rückmeldung und kontinuierliche Verbesserung etabliert werden. Nutzerfeedback, insbesondere von Menschen mit Behinderungen, bietet wertvolle Hinweise darauf, wo noch Anpassungen notwendig sind. Die Implementierung eines solchen Feedback-Mecha-

nismus und die regelmäßige Überprüfung der Applikationen helfen dabei, den gesetzlichen Vorgaben nicht nur zum Zeitpunkt der Einführung, sondern auch im laufenden Betrieb gerecht zu werden.

Insgesamt fordert das BFGG einen ganzheitlichen Ansatz, bei dem Barrierefreiheit nicht als nachträgliche Ergänzung, sondern als integraler Bestandteil der gesamten Applikation betrachtet wird.

11.2.4 Ethische Kriterien

Im Zuge der fortschreitenden Digitalisierung und der steigenden Komplexität von Softwarelösungen müssen zunehmend ethische Fragestellungen betrachtet werden. Dabei spielen folgende Aspekte die wichtigsten Rollen:

- Fairness und Transparenz
- Verantwortlichkeit
- Zugänglichkeit
- Nachhaltigkeit
- Einordnung ins Wertesystem des Unternehmens und Umgang mit dem ethischen Dilemma

Daraus ergibt sich eine Vielzahl von Herausforderungen, die es im Entwicklungsprozess und bei der Anwendung digitaler Technologien zu berücksichtigen gilt.

Die Fairness der eingesetzten Algorithmen ist ein zentrales Thema. In der Entwicklung von KI-gestützten Anwendungen, beispielsweise für Vorqualifizierung von CVs, Risikobewertungen, Tarifberechnungen oder Schadensregulierungen, besteht die Gefahr, dass Vorurteile und systematische Verzerrungen in den Datensätzen unreflektiert übernommen werden. Um dies zu vermeiden, ist es notwendig, die Datenquellen kritisch zu hinterfragen und kontinuierlich zu prüfen, ob die eingesetzten Modelle bestimmte Bevölkerungsgruppen systematisch benachteiligen. Dabei kann der Einsatz von Methoden zur Bias-Detektion und -Korrektur helfen, die Objektivität der Entscheidungsfindung zu erhöhen. Ergänzend dazu sollte die Transparenz der Algorithmen verbessert werden, sodass nicht nur Entwickler, sondern auch unabhängige Prüfinstanzen und gegebenenfalls die betroffenen Kunden Einblick in die Funktionsweise der Systeme erhalten. Die Offenlegung von nachvollziehbaren Entscheidungsbäumen kann dazu beitragen, das Vertrauen in automatisierte Systeme zu erhöhen und Missverständnisse oder gar Fehlinterpretationen zu vermeiden. Dieses Thema ist inzwischen durch die EU gesetzlich geregelt (siehe auch Abschnitt 11.2.3 Der EU AI Act).

Die Zuweisung von Verantwortung und Haftung bildet einen weiteren zentralen Pfeiler ethischer Überlegungen. Bei der Nutzung von Softwarelösungen stellt sich oft die

Frage, wer im Falle von Fehlentscheidungen oder unerwarteten Systemausfällen die Verantwortung trägt – ob dies bei den Entwicklern, den Betreibern oder den Endanwendern liegt. Eine klare und transparente Festlegung von Verantwortlichkeiten, die bereits in der Entwicklungsphase durch entsprechende vertragliche Regelungen und interne Richtlinien festgelegt wird, ist hier unerlässlich. Darüber hinaus ist es ratsam, im Rahmen des sogenannten „human in the loop“-Prinzips sicherzustellen, dass kritische Entscheidungen nicht vollständig automatisiert getroffen werden, sondern stets eine menschliche Überprüfung erfolgen kann. Diese Vorgehensweise hilft nicht nur, mögliche Fehler frühzeitig zu identifizieren und zu korrigieren, sondern stärkt auch das Vertrauen der Kunden in den Entscheidungsprozess.

Ein weiterer wichtiger Aspekt ist die Zugänglichkeit digitaler Lösungen. Versicherungsunternehmen müssen sicherstellen, dass ihre Software nicht nur technologisch fortschrittlich, sondern auch inklusiv gestaltet ist. Dies bedeutet, dass digitale Anwendungen barrierefrei sein müssen, sodass auch Menschen mit körperlichen oder kognitiven Einschränkungen, ältere Personen oder technisch weniger versierte Nutzer problemlos darauf zugreifen können. Hierzu zählen auch benutzerfreundliche Interfaces, intuitive Navigation sowie alternative Kommunikationswege, etwa für jene, die persönliche Beratung bevorzugen. Gleichzeitig sollten Unternehmen darauf achten, dass die zunehmende Digitalisierung nicht zu einer sozialen Spaltung führt, bei der einkommensschwächere Bevölkerungsgruppen, die auf traditionelle, persönliche Beratung angewiesen sind, abgehängt werden. Dieses Thema ist inzwischen durch die EU gesetzlich geregelt (siehe auch Abschnitt 11.2.3 Das Barrierefreiheitsstärkungsgesetz (BFSG)).

Nicht zuletzt rückt die Nachhaltigkeit in den Fokus. Neben der ökonomischen Effizienz und der funktionalen Leistungsfähigkeit müssen auch ökologische und langfristige gesellschaftliche Auswirkungen von Softwarelösungen bedacht werden. Die zunehmende Nutzung von Cloud-Diensten und KI-Anwendungen führt zu einem erheblichen Energieverbrauch, der unter dem Gesichtspunkt des Umweltschutzes kritisch bewertet werden muss. Eine hochkomplexe Aufgabe an ein System der generativen KI kann schon mal den Tagesenergieverbrauch einer Kleinstadt fressen. Unternehmen sind gefordert, ressourcenschonende Technologien zu implementieren und kontinuierlich an der Optimierung des Energieverbrauchs zu arbeiten.

Ergänzt wird das ethische Fundament moderner Softwarelösungen durch die Implementierung und Einhaltung interner ethischer Leitlinien. Viele Versicherer haben bereits Ethik-Boards eingerichtet, die als unabhängige Instanzen die ethischen Konsequenzen technologischer Entwicklungen überwachen und beratend zur Seite stehen. Das Konzept „Ethics by Design“ stellt sicher, dass ethische Überlegungen nicht nachträglich auf Basis des Unternehmens-Wertesystems implementiert werden, sondern von Anfang an integraler Bestandteil des Entwicklungsprozesses sind. Dies umfasst

neben technischen Aspekten auch Schulungen und Sensibilisierungsmaßnahmen zu ethischen Fragestellungen.

Last but not least ist es sehr nützlich, sich eingehend mit dem sogenannten ethischen Dilemma zu befassen. Es handelt sich um eine Situation, in der man sich zwischen dem erzielbaren Nutzen (für Unternehmen, Mitarbeiter und Kunden) und den daraus entstehenden ethischen Risiken entscheiden muss. Hier ein paar Beispiele für ein ethisches Dilemma in IT-Projekten eines Versicherungsunternehmens:

■ BEISPIELE

- **Datenschutz und Privatsphäre:** Speicherung großer Mengen an persönlichen Daten. Ein ethisches Dilemma entsteht, wenn es darum geht, wie diese Daten verwendet und geschützt werden. Sollten Daten für Marketingzwecke genutzt werden, auch wenn dies die Privatsphäre der Kunden beeinträchtigen könnte?
- **Algorithmische Fairness:** Verwendung von Algorithmen zur Risikobewertung. Dies ist gut für Unternehmen und Kunden. Ein Dilemma kann entstehen, wenn diese Algorithmen unbewusst diskriminierende Muster enthalten, die bestimmte Gruppen benachteiligen.
- **Automatisierung und Arbeitsplatzverlust:** Die Einführung von IT-/KI-Systemen kann zur Automatisierung von Prozessen führen, wodurch möglicherweise Arbeitsplätze gefährdet werden. Ein ethisches Dilemma besteht in der Entscheidung zwischen Nutzen für Unternehmen und dessen Mitarbeiter versus Risiken für einzelne Mitarbeiter. ■

Zusammenfassung

Erfolgreiche Projektsteuerung setzt voraus, dass durchgängig über alle Projektphasen hinweg die relevanten Entscheidungskriterien bewertet werden – zu Beginn des Projekts auf Basis von Annahmen und groben Anforderungen – kurz vor Umsetzung und Inbetriebnahme mit höchster Sorgfalt. Mit dieser Systematik wird sichergestellt, dass das Projekt aus unternehmerischer Sicht erfolgreich wird und gleichzeitig sich nicht zu einem Risiko für die Geschäftsleitung wegen Verletzung wichtiger gesetzlicher, regulatorischer oder ethischer Anforderungen entwickelt.

11.3 Der Stage-Gate®-Prozess bei der Proxi-mus Versicherung AG

Max und Lisa waren nach diesen Ausführungen ziemlich erschlagen und konnten sich nicht vorstellen, dass jedes Projekt, kleine und große, gleichermaßen durch so einen aufwändigen Steuerungs- und Entscheidungsmechanismus getragen werden muss. Beide waren etwas beunruhigt bei der Vorstellung, das alles jetzt den Kollegen vom Vertrieb erklären zu müssen. Internes Consulting soll ja die Dinge ermöglichen und nicht verhindern.

Teilweise kann sie der Leiter des PMO beruhigen: Da uns der organisatorisch-prozessuale Reifegrad fehlte, haben wir uns entschieden, nicht gleich in die Vollen zu gehen, sondern nach und nach, also evolutionär die wichtigsten Stage-Gates bei uns einzuführen und zu stabilisieren. Mitarbeiter des PMO haben die Projektleiter aus dem Fachbereich an die Hand genommen und mit ihnen gemeinsam die nötigen Entscheidungsdokumente erarbeitet und die nötigen Prüfungen bei den entsprechenden Instanzen eingeholt. Dabei beobachteten wir ein schwingungsähnliches Verhalten – aus dem Zustand des unregelmäßigen Startens von Projekten gingen wir über in ein überformales Handeln. Dies lag an der Unsicherheit der beteiligten Akteure und jeder war päpstlicher als der Papst. Als man dann bemerkte, dass der Formalaufwand teilweise den Projektaufwand überstieg, regelte sich das fast von alleine wieder runter. Heute haben wir einen sehr pragmatischen Stand, der sich in dieser Form auch in der Projektmanagement-Leitlinie wiederfindet und somit verpflichtend ist.

Es gibt folgende Gates:

Gate 1	Idee → Konzept	Die Projektidee wird freigegeben und die Erstellung eines Konzepts wird beauftragt
Gate 2	Konzept → Umsetzung	Das Konzept wird freigegeben und die Umsetzung des Projekts wird beauftragt
Gate 3	Inbetriebnahme	Die fertiggestellte Software-Lösung wird zur Inbetriebnahme freigegeben

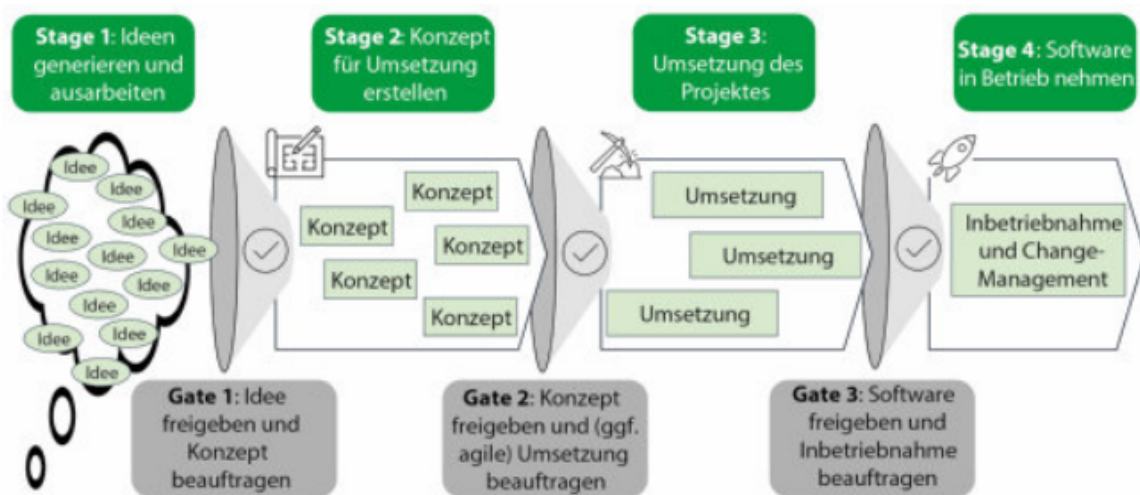


Abbildung 11.3: Stage-Gate®-Modell der Proximus Versicherung AG

Für die Beantragung von Gate-Entscheidungen gibt es Projektantragsformulare des PMO. Ein Beispiel für so einen Projektantrag findet sich im Kapitel Projektmanagement. Wir haben schnell die Erfahrung gemacht, dass wir den Grad des Formalismus proportional zur erwarteten Größe des Projekts steuern müssen, wobei sich im Begriff Größe Dimensionen wie Aufwand, Kosten, Tragweite oder Risiken wiederfinden. Es

darf nicht sein, dass man für ein kleines Projekt den gleichen formalen Aufwand betreibt, wie für ein Megaprojekt zur Ablösung des Kernversicherungssystems. Damit würde man jegliche Innovation im Keim ersticken. Allerdings darf der Formalismus auch nicht ausgesetzt werden, denn ansonsten läuft man Gefahr, Projekte durchzuwinken, die sich später zu sogenannten Trojanern („erstmal klein durch die Türe und das dicke Ende kommt später“) entwickeln oder das Unternehmen erheblichen finanziell-regulatorischen Risiken aussetzen.

Gesteuert wird das alles durch das PMO im Auftrag des Vorstands. Entscheidungen werden getroffen in regelmäßigen Treffen der relevanten Entscheider und Stakeholder in Form eines Projekt-Management-Boards (PMB). Es hat sich als förderlich erwiesen, die Veto-Gremien (Controlling, Datenschutz, Compliance, BR etc.) zeitig einzubinden. In solchen Meetings müssen auch immer wieder Priorisierungsentscheidungen getroffen werden. Hierzu helfen die oben erläuterten Kriterienkataloge. Bei begrenzter Kapazität kommen nur die Projekte mit hoher Priorität zum Zuge – gesetzliche Anforderungen schlagen fast alles – und dann gilt in der Regel der bessere Business Case. Es lohnt sich also, hier viel Sorgfalt reinzustecken.

Das PMO visualisiert das aktuelle Projektportfolio in den Dimensionen Laufzeit von bis und aktuellem Stage.

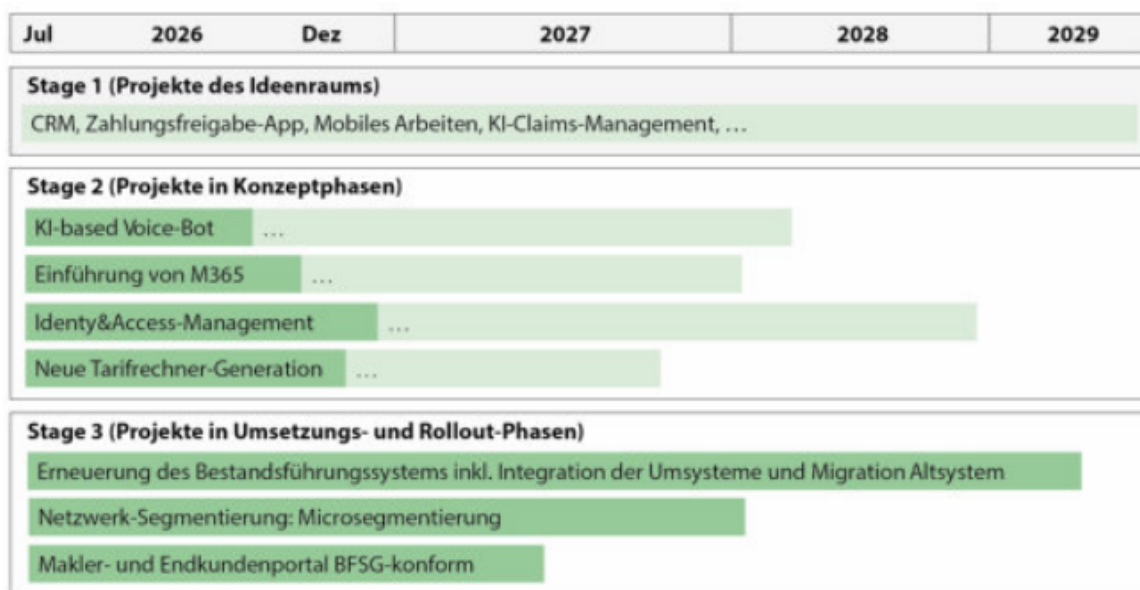


Abbildung 11.4: Die Stages in der Portfoliosicht des PMO mit Beispielprojekten

Für die Kollegen vom Vertrieb würde das im Zeitraffer also ungefähr folgendermaßen aussehen: